ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Siemens SIMATIC WinCC (SCADA / HMI) · Component type: **Software Application (SAR) - SCADA/HMI** · Target SL = SL 3

Where to work	**WinCC User Administrator** + **SIMATIC Logon** (central user/role mgmt, AD groups); WinCC **Audit** (audit trail / e-signature); project & runtime **access protection**; secure comm to controllers; Web Navigator/DataMonitor config. Underlying **Windows Server** hardening applies.
Interfaces / ports	SCADA/HMI runtime; S7/OPC UA to PLCs; WinCC Web (IIS 443); SQL Server (WinCC archive); RDP for engineering. Client/server (WinCC) or single station.
Notes	SAR (software application). Applies to SIMATIC WinCC (V7.x) / WinCC Runtime Professional. Many platform controls are inherited from the Windows host cheat sheet — reference it alongside.
How to read	Read-only: review WinCC/SIMATIC Logon config, audit settings, and the hosting Windows policy. Native how-to + external-tool validation + pass. Scans authorized; exploit/fuzz only in an isolated environment.

Project capture & evidence handling - capture the full application backup + exports

Do this BEFORE working the checklist - screenshots of the config and programming screens are not enough on their own. Capture the application's own backup and exports so nothing is missed:
1. Take the native full backup / export first (read-only, before anything): the WinCC project backup / archive (Project Duplicator, or the TIA Portal project), the User Administrator (users/roles) export, the tag / alarm configuration, and the application + Windows logs.
2. Export the security config: users / roles / permissions, authentication / IdP settings, audit configuration, and TLS / certificate settings - as files and screenshots.
3. Collect the logs: application, service / wrapper, audit and event logs (exports), plus running-threads / diagnostics dumps where the product provides them.
4. Capture identity & version: product edition + version / patch level, installed modules / components, and the host OS / runtime (JRE / .NET) - screenshot the About / version screen.
5. Name + protect (keep everything): `<site>_<zone>_<assetTag>_<product>_<version>_<YYYYMMDD-HHMM>_<initials>` with the native backup extension + the exports; SHA-256 hash the backup; store **only** on the encrypted evidence share; the backup usually contains secrets / credentials - **never** email it in cleartext and follow the project retention / classification policy. Do not save admin passwords in tool profiles.
6. Then analyze offsite against the product-specific checklist, the product manuals, vendor research and experience; fill in the tool and auto-generate the report - and remember the manual fields the tool can't auto-write: the **executive-summary narrative**, the **overall assurance level + justification**, and the **punch-list**.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 1.1	Human user identification & auth	Confirm **SIMATIC Logon** is enabled so every operator/engineer authenticates (against Windows/AD) before runtime or configuration access; no anonymous/auto-login accounts. **Ext. tools:** WinCC User Administrator / SIMATIC Logon review.	All access authenticated via SIMATIC Logon / AD; no anonymous use.	
SR/CR 1.2	Software process & device identification & authentication	Confirm devices and software processes are identified/authenticated to the component. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Software process & device identification & authentication verified individually.	
SR/CR 1.3	Account management	Manage WinCC user groups/authorizations centrally (SIMATIC Logon + AD groups): create/modify/disable, least-privilege authorization levels (operate vs configure vs admin); no shared logins. **Ext. tools:** User Administrator (groups/levels); AD group review.	Accounts managed centrally; least-privilege; no shared logins.	
SR/CR 1.4	Identifier management	Confirm unique user identifiers (AD/SIMATIC Logon) mapped to WinCC groups; no reuse; the station/project has a unique identity. **Ext. tools:** AD/SIMATIC Logon user review.	Unique user identifiers; no reuse.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 1.5	Authenticator management	Enforce password policy via AD (SIMATIC Logon delegates to Windows): length/complexity/expiry/history; change all defaults; manage lifecycle centrally. **Ext. tools:** AD password policy (secpol/GPO) review.	Strong, centrally-managed authenticators; no defaults.	
SR 1.6	Wireless Access Management	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	PKI certificates	Confirm certificates for WinCC Web (IIS/HTTPS), OPC UA, and secure comm to PLCs are CA-issued, valid, and not default self-signed; trust list managed. **Ext. tools:** Browser/openssl (IIS 443, OPC UA 4840); cert store review.	CA-issued, valid certificates; defaults replaced.	
SR/CR 1.9	Strength of public key auth	Confirm TLS 1.2/1.3 with strong ciphers on Web/OPC UA/secure comm; OPC UA policy Basic256Sha256+; no weak/expired certs. **Ext. tools:** testssl.sh; OPC UA client (policy check).	Strong certificate/TLS crypto; weak protocols disabled.	
SR/CR 1.10	Authenticator feedback	Confirm the WinCC logon dialog, Web login, and SIMATIC Logon mask password entry (no cleartext echo). **Ext. tools:** Visual verification.	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	Confirm lockout on repeated failures (AD account lockout via SIMATIC Logon) and that failures are recorded in the audit trail / Windows security log. **Ext. tools:** AD lockout policy; audit-trail / Event Viewer review.	Failed logins locked out and logged.	
SR/CR 1.12	System use notification	Confirm the approved use-notification banner appears before access (Windows interactive-logon banner on the WinCC station; Web login notice where supported). **Ext. tools:** GPO logon banner; Web login page review.	Approved use notification presented before access.	
SR 1.13	Access via untrusted networks	Confirm WinCC clients/Web are reachable only from trusted zones (operator LAN), remote engineering via VPN/jump host; deny direct access from untrusted networks. **Ext. tools:** Nmap (from untrusted side); firewall rule review.	Access from untrusted networks denied/brokered; remote via VPN.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 2.1	Authorization enforcement	Confirm WinCC **authorization levels** enforce operate vs configure vs administer; screen/tag/action rights bound to groups; unauthorized operations denied. **Ext. tools:** User Administrator (authorizations); attempt unauthorized action (isolated).	Least-privilege authorization enforced in runtime and config.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR 2.3	Use control for portable/mobile devices	Control removable media on the WinCC station (Windows device control / removable-storage GPO); no unmanaged media loads projects/updates. **Ext. tools:** GPO device-control review (see Windows sheet).	Removable-media use controlled on the station.	
SR/SAR 2.4	Mobile code	Restrict active/mobile code: Web Navigator content controlled, VBS/C-scripts in the project reviewed/limited, app allow-listing (AppLocker/WDAC) on the host; no untrusted code executes. **Ext. tools:** Project script review; AppLocker/WDAC policy.	Only trusted project code runs; untrusted mobile code blocked.	SAR-specific.
SR/CR 2.5	Session lock	Confirm runtime auto-logoff on inactivity (WinCC logoff timer) and OS screen-lock; re-authentication required to resume. **Ext. tools:** WinCC logoff-time config; GPO screen-lock.	Sessions lock/log off on inactivity; re-auth required.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 2.6	Remote session termination	Confirm Web/RDP sessions time out and can be terminated by admin; WinCC clients can be logged off centrally. **Ext. tools:** RDP/Web timeout config; session review.	Remote sessions time out and are terminable on demand.	
SR/CR 2.7	Concurrent session control	Confirm concurrent client/Web sessions are limited by license and policy; no shared concurrent privileged logins. **Ext. tools:** WinCC client/Web session review.	Concurrent sessions limited/monitored.	
SR/CR 2.8	Auditable events	Enable **WinCC/Audit** (audit trail of operator actions/tag changes/config, with electronic records & e-signatures) and the **SIMATIC Logon Eventlog Viewer** (logon/logoff, authentication, password changes); actions bind to the authenticated user; forward events to the SIEM. **Ext. tools:** WinCC/Audit + SIMATIC Logon Eventlog Viewer; SIEM forwarding review.	Operator/config actions audited (e-signature) and attributable.	
SR/CR 2.9	Audit storage capacity	Confirm audit/alarm/archive storage (SQL Server) is sized, backed up, and offloaded so records are retained; forward security events to the SIEM. **Ext. tools:** SQL archive sizing; SIEM retention review.	Audit/archive storage sized and retained.	
SR/CR 2.10	Response to audit processing failures	Confirm defined behavior on archive/audit failure (alarm on archive stop, SIEM alert on forwarding loss); records not silently lost. **Ext. tools:** WinCC archive alarms; SIEM agent-health alert.	Defined response to audit failure; alerting on loss.	
SR/CR 2.11	Timestamps	Confirm the WinCC server and clients are time-synced (NTP/AD) so alarm/audit timestamps are accurate and correlate with controllers. **Ext. tools:** w32tm / NTP config review.	Reliable, synchronized timestamps.	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 3.1	Communication integrity	Use **secure communication** to controllers (S7 Secure Comm / OPC UA sign+encrypt) and TLS for Web/DataMonitor; avoid legacy cleartext channels; segment SCADA traffic. **Ext. tools:** Wireshark (encrypted channels); OPC UA policy.	Comms integrity/confidentiality -protected on secured channels.	
SR/SAR 3.2	Protection from malicious code (component)	Confirm the WinCC host runs endpoint protection compatible with the Siemens compatibility list, app allow-listing, and project script controls so the SCADA application resists malicious code. **Ext. tools:** AV/allow-list review (per Siemens compat); project integrity check.	Application protected from malicious code (allow-listed, AV per compat).	SAR-specific.
SR/CR 3.3	Security functionality verification	After change, re-verify SIMATIC Logon config, authorizations, audit settings, certificates, and the host hardening (STIG/CIS) against the baseline. **Ext. tools:** SCAP/STIG scan of host; WinCC config compare.	Security settings match the baseline after change.	
SR/CR 3.4	Software & information integrity	Confirm project integrity: project **access protection** (password), version/change control (WinCC Audit), and controlled deployment so unauthorized project changes are prevented/detected. **Ext. tools:** Project protection review; audit-trail change history.	Project integrity protected; unauthorized change prevented/detected.	
SR/CR 3.5	Input validation	Confirm WinCC-exposed services (Web, OPC UA, comm channels) tolerate malformed input without crashing; keep patched to current Siemens updates; fuzz only in a lab. **Ext. tools:** Siemens ProductCERT/patch review; API fuzz (ISOLATED).	Patched against input-validation CVEs; no crash on malformed input.	Do NOT fuzz production.
SR/CR 3.6	Deterministic Output	**N/A.** Device does not drive process outputs; deterministic/fail-safe output is not applicable.	N/A - justification recorded (not assessed as a control).	N/A

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 3.7	Error handling	Confirm runtime handles faults/comm loss gracefully (redundancy failover where used, no info leakage in error dialogs, clean recovery). **Ext. tools:** Redundancy/failover test (lab); error-dialog review.	Graceful error handling; no sensitive info leak.	
SR/CR 3.8	Session integrity	Confirm Web/OPC UA/client sessions are integrity-protected (TLS), replay-resistant; old sessions cannot be replayed. **Ext. tools:** Wireshark (TLS session inspection).	Sessions integrity-protected against replay/hijack.	
SR/CR 3.9	Protection of audit information	Protect the WinCC Audit trail and archives: restricted DB access, forwarded to a write-once SIEM, so records cannot be altered/deleted by unauthorized users. **Ext. tools:** SQL permission review; SIEM immutability.	Audit records protected from unauthorized read/modify/delete.	

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/reuse, remove the WinCC project, archives, credentials, and certificates; sanitize the host storage (BitLocker crypto-erase / wipe) so data is not recoverable. **Ext. tools:** Project/archive removal; host sanitize (see Windows sheet).	Sensitive project/archive data purged on decommission.	
SR/CR 4.3	Use of cryptography	Confirm modern crypto for Web/OPC UA/secure comm (TLS 1.2/1.3, strong suites) and that stored credentials/keys are protected; disable weak protocols. **Ext. tools:** testssl.sh; crypto config review.	Modern crypto in use; weak protocols disabled.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 5.1	Network segmentation	Confirm ES/OS and controller networks are segmented (SCADA zone behind firewall), WinCC Web in a DMZ/reverse-proxy where remote, and only required flows cross the boundary. **Ext. tools:** Nmap by zone; firewall/DMZ review.	SCADA segmented into zones; only required flows cross.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General-purpose person-to-person comms restrictions	Confirm the WinCC station is single-purpose: email/IM/arbitrary web removed or blocked, app allow-listing + egress filtering so it cannot be used for person-to-person messaging. **Ext. tools:** App inventory; egress/proxy review.	No general-purpose person-to-person comms on the station.	
SR 5.4	Application partitioning	Confirm separation of engineering (ES) from operator (OS) and of WinCC server roles; least-privilege accounts and, for high assurance, dedicated servers per function. **Ext. tools:** ES/OS separation review; role/account review.	Roles/applications partitioned to contain compromise.	

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 6.1	Audit log accessibility	Confirm WinCC Audit/alarms are readable/exportable and forwarded to the SIEM for continuous monitoring; the SCADA zone is monitored (IDS). **Ext. tools:** Syslog/SIEM forwarding; passive OT IDS.	Events accessible/exportable and monitored in near-real-time.	
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 7.1	Denial-of-service protection	Confirm DoS resilience: host firewall + WinCC redundancy, only required services exposed, connection limits; a flood does not deny SCADA operation. **Ext. tools:** Get-NetFirewallProfile; Nmap; load test (ISOLATED).	Attack surface minimized; SCADA resists DoS (redundancy where used).	
SR/CR 7.2	Resource management	Confirm host/DB resource controls (CPU/memory/disk limits, SQL sizing, archive rotation) so one process cannot starve the SCADA server. **Ext. tools:** Performance Monitor; SQL/archive config review.	Resources bounded; no single-process exhaustion.	
SR/CR 7.3	Control system backup	Confirm the WinCC project, archives, and station image are backed up (versioned, offline) and restore is tested for a known-good rebuild; redundancy validated. **Ext. tools:** Backup repository review; restore test (lab).	Backups current and recovery validated.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security configuration settings	Confirm hardening: unused WinCC options/Web disabled, host services minimized (per Siemens security guideline), SQL/OPC endpoints restricted. **Ext. tools:** Service/option review; Nmap (exposed services).	Least functionality; unused services disabled per baseline.	
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Confirm WinCC version, patches, options, and host are inventoried so vulnerabilities track against Siemens ProductCERT advisories. **Ext. tools:** ReadOnlyEnum; WinCC version/patch inventory.	Accurate software/version inventory maintained.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
WinCC User Administrator / SIMATIC Logon	Identity, roles & authorization review (FR1, 2.1)	Read user groups, authorization levels, and AD integration; confirm least privilege and no shared logins.	Read/authorized copy.
WinCC Audit	Audit trail & change control review (2.8, 3.4, 3.9)	Confirm operator/config actions and e-signatures are recorded and protected.	Non-intrusive.

Tool / method	Verifies	How to use — steps / example	Constraints
SCAP/STIG (host)	Host hardening verification (3.3, 7.6)	Scan the hosting Windows Server against the STIG/CIS baseline; reference the Windows cheat sheet.	Authorized.
Nmap / ReadOnlyEnum	Exposed-service & zone enumeration (1.13, 5.x, 7.6, 7.8)	Enumerate Web/OPC UA/SQL/RDP from each zone; confirm only required services reachable.	Read-only; authorized.
testssl.sh / OPC UA client	TLS & OPC UA strength (1.8, 1.9, 4.3)	Check TLS/cipher strength on IIS/OPC UA and the OPC UA security policy.	Non-intrusive.
Syslog listener + SIEM	Event forwarding & monitoring (2.8-2.10, 6.x)	Confirm audit/security events reach the SIEM; trigger a test event.	Coordinate with SIEM team.